

STAC4749 POWERSHELL PAYLOAD RETRIEVAL

Source-observed PowerShell staging into AppData\Roaming followed by tokenized implant launch.

HUNTING QUERY

CONFIDENCE: MEDIUM

SOURCE-CONFIRMED BEHAVIOR

retain facts, isolate interpretation

DeviceProcessEvents

direct telemetry boundary

HUNT · VALIDATE · TUNE

no automatic malicious verdict

REPORT DATE

02 August 2026

VERSION

v1.0-corrected

PRIMARY TELEMETRY

Microsoft Defender XDR ·
DeviceProcessEvents

ATT&CK

T1059.001 · T1105

Evidence-led dossier. Query status remains an untested
implementation sketch until executed in the target environment.

INDEPENDENT RESEARCH FORMAT · CONTROLLED UI/UX MASTER

01

EXECUTIVE ASSESSMENT

Decision-grade summary for detection engineering and SOC operations.

ASSESSMENT

EXECUTIVE SUMMARY

Retain the complete source-observed command chain.

The hunt requires PowerShell retrieval, AppData\Roaming staging, Start-Process and the --token-raw argument in one process command line. It is more selective than alerting on PowerShell or remote-support software alone.

OPERATIONAL VALUE

Useful before confirmed ransomware impact.

The pattern creates an investigable endpoint pivot during the payload-staging phase, while avoiding unsupported claims about C2 success, data theft or later Chaos ransomware deployment.

8.2

01

OPERATIONAL VALUE



Medium

02

DETECTION CONFIDENCE



Hunting

03

OPERATIONAL READINESS



SOURCE-CONFIRMED FACTS

Observed behavior

- Sophos MDR observed Teams vishing followed by remote access.
- A one-line PowerShell command used Invoke-WebRequest, -OutFile and Start-Process.
- The destination was under AppData\Roaming and the launch included --token-raw.

ANALYTICAL ASSESSMENT

What the evidence supports

- The combined command chain is campaign-specific and operationally useful.
- Single elements such as PowerShell, AppData or remote support are insufficient alone.
- A match is a hunt lead, not attribution or proof of ransomware.

DETECTION ASSUMPTIONS

What must be validated

- ProcessCommandLine is complete and retained.
- Authorized administration does not reproduce the complete chain at scale.
- Device and process identifiers are populated consistently.

Confidence boundary

The token argument and path are mutable. The query is not a durable behavioral Production candidate until local prevalence and evasion paths are measured.

02

THREAT MECHANICS

Source-observed chain and explicit observability boundaries.

ATTACK FLOW

01

Teams vishing

External support impersonation initiates contact.

02

Remote session

Quick Assist or RemSupp enables operator access.

03

Payload staging

PowerShell writes an executable under AppData\Roaming.

04

Tokenized launch

Start-Process executes the payload with --token-raw.

05

Follow-on access

Backdoors or RMM may support later activity.

Observable core

A PowerShell process command line containing the complete retrieval, output path and launch sequence.

Non-observable boundary

Teams call content, user consent, encrypted payload contents, successful C2 and ransomware outcome.

DETECTION HYPOTHESIS

Source-observed staging should remain visible in process telemetry.

If the attacker repeats the documented staging command, DeviceProcessEvents should show PowerShell combining Invoke-WebRequest, -OutFile to AppData\Roaming, Start-Process and --token-raw. Authorization, parentage, payload identity and network follow-on distinguish legitimate activity.

REQUIRED TELEMETRY

DeviceProcessEvents

- MDE process creation events.
- Full ProcessCommandLine.
- DeviceId and process correlation key.

OPTIONAL ENRICHMENT

Context that improves disposition

- File hash, signer and origin.
- Parent and remote-support session.
- Network connections from launched payload.

UNAVAILABLE HERE

Do not infer

- Teams conversation content.
- C2 success or payload behavior.
- Ransomware outcome.



TELEMETRY & EVIDENCE MODEL

Minimum data contract and quality gates for a defensible hunt.

DATA CONTRACT

PRIMARY DATA SOURCE

Microsoft Defender XDR - DeviceProcessEvents

Provides process creation, command line, device, account and parent-process context.

EVIDENCE BOUNDARY

A matching event is a lead, not a verdict.

The table records execution metadata; it does not expose the downloaded payload body or prove network success.

REQUIRED AND ENRICHMENT FIELD MODEL

CATEGORY	FIELD	PURPOSE	REQUIREMENT
Process event	DeviceProcessEvents	Primary command-line evidence.	REQUIRED
Process identity	FileName, FolderPath	PowerShell image context.	REQUIRED
Command	ProcessCommandLine	All evidence-bearing filters.	REQUIRED
Device	DeviceId, DeviceName	Endpoint pivot.	REQUIRED
Account	AccountUpn, AccountName	Authorization check.	OPTIONAL
Process key	ProcessUniqueId	Stable process correlation.	REQUIRED
File/network	DeviceFileEvents, DeviceNetworkEvents	Follow-on enrichment.	ENRICHMENT

Data quality requirements

- Complete, untruncated command lines.
- Stable DeviceId and ProcessUniqueId.
- Representative retention window.
- Raw-event access for validation.

Known failure conditions

- PowerShell logging gap or truncated command line.
- Direct payload launch without the observed token.
- Different staging directory or downloader.
- Authorized script reproduces the full pattern.



DETECTION LOGIC

Primary-platform hunt with every condition traceable to evidence.

HUNTING QUERY

DETECTION OBJECTIVE

Find the documented retrieval-and-launch chain.

Select PowerShell processes only when every source-observed command component is present.

ANALYTICAL LOGIC

Direct filters and investigable output.

Direct contains filters; no join, aggregation, rarity, arbitrary threshold or automatic verdict.

KQL · DEMONSTRATIVE

```
// STAC4749 PowerShell payload retrieval and tokenized implant launch
// Classification: Hunting query - Untested implementation sketch
// Confidence: Medium
// Platform: Microsoft Defender XDR Advanced Hunting
// Telemetry prerequisite: Microsoft Defender for Endpoint populating DeviceProcessEvents
// Evidence: Sophos observed this command pattern in STAC4749 incidents (Feb-Jun 2026).
// This campaign-specific hunt is not suitable for alerting until benign overlap is measured.
DeviceProcessEvents
| where FileName in~ ("powershell.exe", "pwsh.exe")
| where ProcessCommandLine contains "Invoke-WebRequest"
| where ProcessCommandLine contains "-OutFile"
| where ProcessCommandLine contains "--token-raw"
| where ProcessCommandLine contains "Start-Process"
| where ProcessCommandLine contains @"%AppData%\Roaming\"
| project Timestamp, DeviceId, DeviceName, AccountUpn, AccountName,
  FileName, FolderPath, ProcessCommandLine,
  InitiatingProcessFileName, InitiatingProcessCommandLine,
  ProcessId, ProcessUniqueId, ReportId
| order by Timestamp desc
```

REVIEW FIELDS · BASELINE LOCALLY · VALIDATE BEFORE PRODUCTION

STATUS	THRESHOLD	JOIN / SEQUENCE	PRIMARY KEY	DISPOSITION
Untested hunting	None	None	DeviceId + ProcessUniqueId	Manual triage

What a match means

A source-observed PowerShell staging pattern occurred on the endpoint and requires authorization and payload review.

What a match does not prove

Successful C2, malware identity, ransomware deployment, data theft or attribution.



TRIAGE & INVESTIGATION

Evidence collection before escalation.

SOC WORKFLOW

NUMBERED WORKFLOW

- 01

Confirm raw event.
Verify complete command line, user, device, parent and process key.
- 02

Validate authorization.
Check change records, deployment tooling and red-team activity.
- 03

Pivot to file evidence.
Collect target path, hash, signer and creation origin.
- 04

Pivot to network.
Inspect connections from the launched process without inferring C2 success.
- 05

Review remote access.
Establish whether the support session was authorized.

Escalation gate

Escalate when the complete command is unauthorized and corroborated by suspicious payload, remote-support abuse, persistence or network activity.

Primary benign overlap

Enterprise deployment scripts, red-team simulations and vendor support tooling may overlap only if they reproduce the full command chain.

INVESTIGATION PIVOTS

Host
Coverage, recent changes and neighboring alerts.

User
Authorization and session context.

Process
Parent, command line and child processes.

File
Hash, signer, origin and prevalence.

Network
Destinations after payload launch.

RMM
Quick Assist, RemSupp or other support tooling.

DISPOSITION CRITERIA

OUTCOME	MINIMUM EVIDENCE	ACTION
BENIGN	Approved, owned and repeatable activity.	Document and tune narrowly.
SUSPICIOUS	Unknown activity without corroborated malicious follow-on.	Deepen endpoint review.
LIKELY MALICIOUS	Unauthorized match plus coherent file, process, network or control-plane evidence.	Escalate incident response.



FALSE POSITIVES & VALIDATION

Operational controls required before promotion.

QUALITY GATE

FALSE-POSITIVE MATRIX

SCENARIO	WHY IT OVERLAPS	TUNING ACTION
Enterprise deployment script	May download and launch software from user paths.	Require signed script, repository, ticket and service account.
Red-team simulation	May intentionally reproduce the source chain.	Scope to approved window and asset; retain as test evidence.
Vendor support workflow	Remote support plus scripted installation.	Validate publisher, owner and stable command provenance.

Baseline plan

- Run across 30-90 days.
- Inspect every raw match.
- Separate workstation and server populations.
- Record authorized command provenance.

Validation procedure

- Confirm command-line completeness.
- Replay a safe equivalent command.
- Compare output with endpoint ground truth.
- Measure missed variants and benign overlap.

TEST CASES

CASE	EXPECTED RESULT
Controlled equivalent command	Expected match with complete fields.
PowerShell download without --token-raw	No match.
Direct payload launch	No match under this campaign hunt.
Authorized script reproducing chain	Match, then narrow contextual tuning.

Hunting

Initial query

Candidate

After field validation

Production

Measured precision

Optimized

Stable feedback

Success

Complete events and low, explainable volume.

Rejection

Frequent legitimate reproduction with no stable discriminator.

Failure

Missing or truncated ProcessCommandLine.



ATT&CK, CONCLUSION & REFERENCES

Coverage statement, residual risk and document control.

CLOSURE

MITRE ATT&CK MAPPING

TECHNIQUE	NAME	COVERAGE STATEMENT
T1059.001 / T1105	PowerShell / Ingress Tool Transfer	Directly covers PowerShell retrieval and launch of an ingress payload.

Detection coverage summary

Strong for the exact command chain; weak for changed arguments, paths or launch methods.

Residual risk

Campaign artifacts are mutable and process-only telemetry cannot confirm payload intent or network success.

ANALYST CONCLUSION

A selective campaign hunt, not a production verdict.

The source-observed command chain is suitable for retrospective hunting and tenant validation. Promotion requires measured benign overlap, field completeness and evidence that tuning remains durable without depending entirely on mutable artifacts.

REFERENCES

- 1. Sophos X-Ops, "Chaos in Teams vishing." <https://www.sophos.com/en-us/blog/chaos-in-teams-vishing>
- 2. Microsoft Learn, "DeviceProcessEvents table." <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-deviceprocessevents-table>

DOCUMENT CONTROL

VERSION	DATE	STATUS	OWNER
v1.0-corrected	02 August 2026	Hunting	Detection Engineering

Publication control

Eight A4 pages. URLs are defanged. No customer data, credentials, HTML source or rendering assets are included in the public repository.